

Progetto Settimanale S11 - L5

di Alessio Lacava

Esercizio 1 - Usare Windows PowerShell

L'obiettivo del laboratorio è esplorare alcune delle funzioni di PowerShell.

- *Parte 1 - Accedere alla console PowerShell.*
- *Parte 2 - Esplorare i comandi del Prompt dei Comandi e di PowerShell.*
- *Parte 3 - Esplorare i cmdlet.*
- *Parte 4 - Esplorare il comando netstat usando PowerShell.*
- *Parte 5 - Svuotare il cestino usando PowerShell.*

Esercizio 2 – Studio di IoC

- *Analizzare il link di AnyRun e descrivere le minacce*

Esercizio Bonus 1 – Esplorazione Nmap

- *Parte 1 - Esplorazione di Nmap*
- *Parte 2 - Scansione delle Porte Aperte*

Esercizio Bonus 2 – Attacco a un Database MySQL

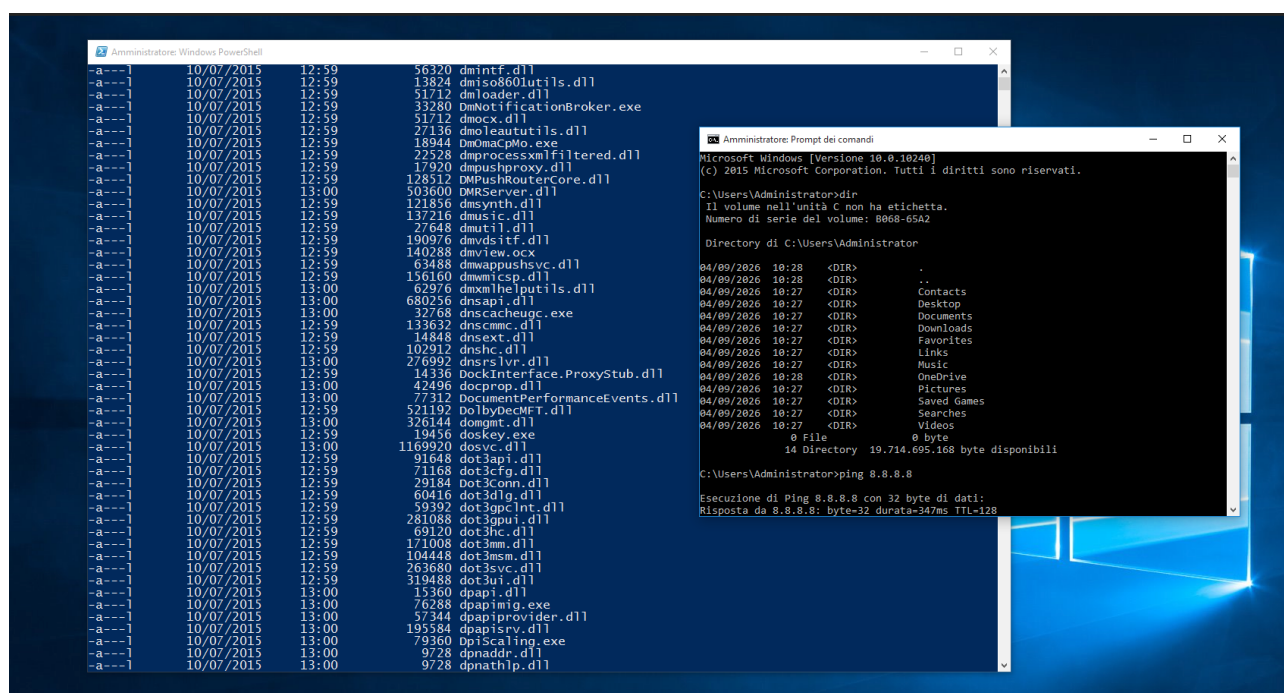
In questo laboratorio, visualizzerai un file PCAP di un attacco precedente contro un database SQL.

- *Parte 1 - Aprire Wireshark e caricare il file PCAP.*
- *Parte 2 - Visualizzare l'attacco di SQL Injection.*
- *Parte 3 - L'attacco di SQL Injection continua...*
- *Parte 4 - L'attacco di SQL Injection fornisce informazioni di sistema.*
- *Parte 5 - L'attacco di SQL Injection e le informazioni sulle tabelle*
- *Parte 6 - L'attacco di SQL Injection si conclude.*

Esercizio 1 - Usare Windows PowerShell

Quali sono gli output del comando dir?

- **Prompt dei Comandi (CMD):** Mostra un testo classico formattato per colonne che include data, ora, il tag <DIR> per le cartelle, la dimensione in byte per i file e il riassunto finale con il conteggio di file e directory, oltre allo spazio libero sul disco.
- **PowerShell:** Restituisce una tabella strutturata (molto lunga) a oggetti con colonne ben definite: Mode (gli attributi di sistema/file, es. -a----), LastWriteTime (data e ora dell'ultima modifica), Length (dimensione in byte) e Name (nome del file o della cartella).



Quali sono i risultati?

- **ping 8.8.8.8:** Esegue un test di connettività inviando 4 pacchetti ICMP v4 da 32 byte verso l'IP di Google e restituendo i tempi di risposta (con un tempo medio di 320ms in PowerShell e 309ms nel CMD) senza alcuna perdita di pacchetti (0% persi).
- **cd:** Nel Prompt dei Comandi, digitato da solo, mostra a schermo il percorso della directory corrente (C:\Users\Administrator). In PowerShell, cd è un alias e richiede un argomento per cambiare posizione; digitandolo da solo non sposta la posizione attiva.
- **ipconfig:** Restituisce le informazioni di configurazione di rete in entrambe le finestre, identificando la scheda Ethernet con IPv4 10.0.2.15 (Gateway 10.0.2.2) e la scheda Ethernet 2 con IPv4 192.168.50.20 (Gateway 192.168.50.1).

```
PS C:\Windows\system32> ping 8.8.8.8
Esecuzione di Ping 8.8.8.8 con 32 byte di dati:
Risposta da 8.8.8.8: byte=32 durata=338ms TTL=128
Risposta da 8.8.8.8: byte=32 durata=357ms TTL=128
Risposta da 8.8.8.8: byte=32 durata=194ms TTL=128
Risposta da 8.8.8.8: byte=32 durata=391ms TTL=128

Statistiche Ping per 8.8.8.8:
    Pacchetti: Trasmessi = 4, Ricevuti = 4,
    Persi = 0 (0% persi),
    Tempo approssimativo percorsi andata/ritorno in millisecondi:
        Minimo = 194ms, Massimo = 391ms, Medio = 320ms
PS C:\Windows\system32> ipconfig

Configurazione IP di Windows

Scheda Ethernet Ethernet:

    Suffisso DNS specifico per connessione:
    Indirizzo IPv4 . . . . . : 10.0.2.15
    Subnet mask . . . . . : 255.255.255.0
    Gateway predefinito . . . . . : 10.0.2.2

Scheda Ethernet Ethernet 2:

    Suffisso DNS specifico per connessione:
    Indirizzo IPv6 locale rispetto al collegamento . : fe80::6826:a80:fa70:3e93%7
    Indirizzo IPv4 . . . . . : 192.168.50.20
    Subnet mask . . . . . : 255.255.255.0
    Gateway predefinito . . . . . : 192.168.50.1

Scheda Tunnel isatap.{ED90F4B0-B795-453A-8571-B2E0D4431674}:

    Stato supporto. . . . . : Supporto disconnesso
    Suffisso DNS specifico per connessione:

Scheda Tunnel isatap.{92D61F82-1D19-45C9-B7CF-2E5AF2D63627}:

    Stato supporto. . . . . : Supporto disconnesso
    Suffisso DNS specifico per connessione:
PS C:\Windows\system32>
```

```
Seleziona Amministratore: Prompt dei comandi
C:\Users\Administrator> ping 8.8.8.8
Esecuzione di Ping 8.8.8.8 con 32 byte di dati:
Risposta da 8.8.8.8: byte=32 durata=347ms TTL=128
Risposta da 8.8.8.8: byte=32 durata=452ms TTL=128
Risposta da 8.8.8.8: byte=32 durata=250ms TTL=128
Risposta da 8.8.8.8: byte=32 durata=189ms TTL=128

Statistiche Ping per 8.8.8.8:
    Pacchetti: Trasmessi = 4, Ricevuti = 4,
    Persi = 0 (0% persi),
    Tempo approssimativo percorsi andata/ritorno in millisecondi:
        Minimo = 189ms, Massimo = 452ms, Medio = 309ms

C:\Users\Administrator> cd
C:\Users\Administrator> ipconfig

Configurazione IP di Windows

Scheda Ethernet Ethernet:

    Suffisso DNS specifico per connessione:
    Indirizzo IPv4 . . . . . : 10.0.2.15
    Subnet mask . . . . . : 255.255.255.0
    Gateway predefinito . . . . . : 10.0.2.2

Scheda Ethernet Ethernet 2:

    Suffisso DNS specifico per connessione:
    Indirizzo IPv6 locale rispetto al collegamento . : fe80::6826:a80:fa70:3e93%7
    Indirizzo IPv4 . . . . . : 192.168.50.20
    Subnet mask . . . . . : 255.255.255.0
    Gateway predefinito . . . . . : 192.168.50.1

Scheda Tunnel isatap.{ED90F4B0-B795-453A-8571-B2E0D4431674}:

    Stato supporto. . . . . : Supporto disconnesso
    Suffisso DNS specifico per connessione:

Scheda Tunnel isatap.{92D61F82-1D19-45C9-B7CF-2E5AF2D63627}:

    Stato supporto. . . . . : Supporto disconnesso
    Suffisso DNS specifico per connessione:
```

Qual è il comando PowerShell per dir?

Il cmdlet nativo di PowerShell associato a `dir` è **Get-ChildItem**. Il termine `dir` funziona in PowerShell unicamente come un alias (scorciatoia) per richiamare questo cmdlet.

Qual è il gateway IPv4?

Dalla configurazione delle schede e dalla tabella di routing (`netstat -r`) si evidenziano due gateway predefiniti attivi:

- **10.0.2.2** per la prima scheda di rete (Ethernet, con IP 10.0.2.15).
- **192.168.50.1** per la seconda scheda di rete (Ethernet 2, con IP 192.168.50.20), che figura anche come gateway predefinito principale nella tabella di routing permanente e per la rotta 0.0.0.0.

```
Amministratore: Windows PowerShell
PS C:\Windows\system32> netstat -r

=====
Elenco interfacce
4...08 00 27 d7 92 09 .....Intel(R) PRO/1000 MT Desktop Adapter
7...08 00 27 a0 ce 39 .....Intel(R) PRO/1000 MT Desktop Adapter #2
1.....Software Loopback Interface 1
6...00 00 00 00 00 00 e0 Microsoft ISATAP Adapter
3...00 00 00 00 00 00 e0 Microsoft ISATAP Adapter #2
=====

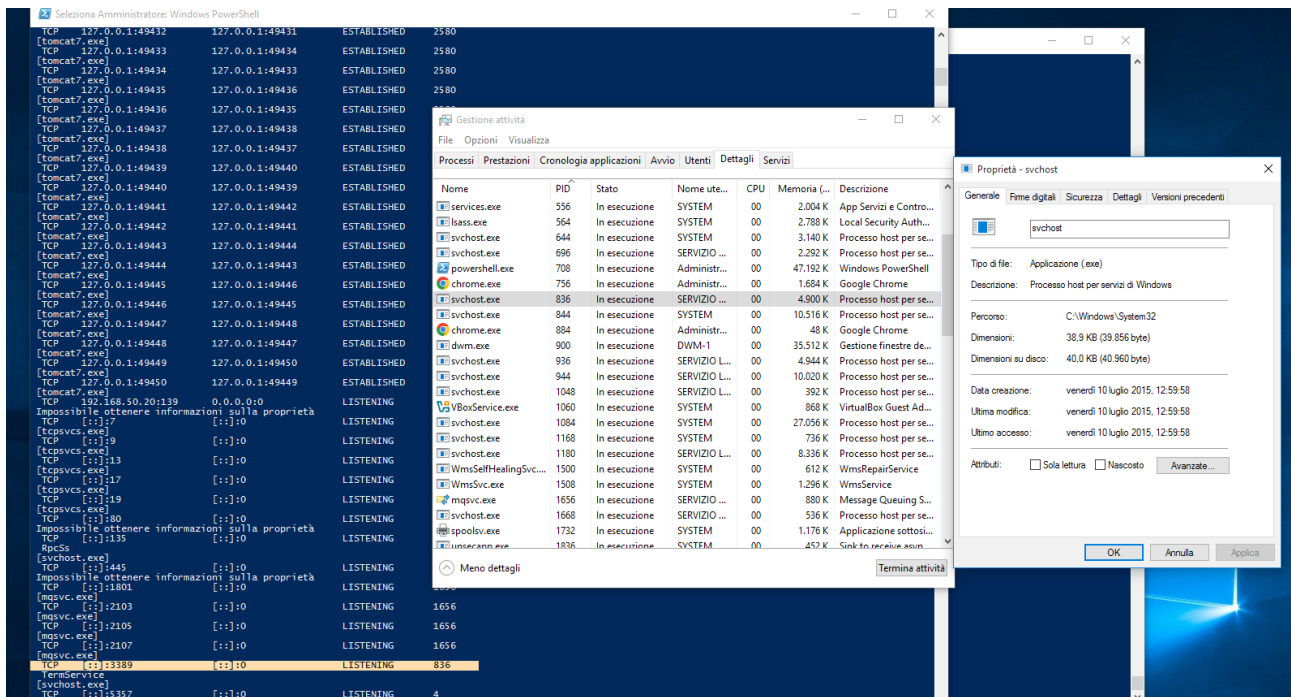
IPv4 Tabella route
=====
Route attive:
Indirizzo rete      Mask      Gateway      Interfaccia  Metrica
0.0.0.0             0.0.0.0    192.168.50.1  192.168.50.20 266
0.0.0.0             0.0.0.0    10.0.2.2      10.0.2.15     10
10.0.2.0            255.255.255.0 On-link      10.0.2.15     266
10.0.2.15           255.255.255.255 On-link      10.0.2.15     266
10.0.2.255          255.255.255.255 On-link      10.0.2.15     266
127.0.0.0            255.0.0.0  On-link      127.0.0.1     306
127.0.0.1           255.255.255.255 On-link      127.0.0.1     306
127.255.255.255     255.255.255.255 On-link      127.0.0.1     306
192.168.50.0         255.255.255.0 On-link      192.168.50.20 266
192.168.50.20        255.255.255.255 On-link      192.168.50.20 266
192.168.50.255       255.255.255.255 On-link      192.168.50.20 266
224.0.0.0            240.0.0.0  On-link      127.0.0.1     306
224.0.0.0            240.0.0.0  On-link      10.0.2.15     266
224.0.0.0            240.0.0.0  On-link      192.168.50.20 266
255.255.255.255     255.255.255.255 On-link      127.0.0.1     306
255.255.255.255     255.255.255.255 On-link      10.0.2.15     266
255.255.255.255     255.255.255.255 On-link      192.168.50.20 266
=====
Route permanenti:
Indirizzo rete      Mask      Indir. gateway Metrica
0.0.0.0             0.0.0.0    192.168.50.1  Predefinito
=====

IPv6 Tabella route
=====
Route attive:
Interf Metrica Rete Destinazione Gateway
1       306 ::1/128      On-link
7       266 fe80::/64   On-link
7       266 fe80::6826:a80:fa70:3e93/128 On-link
1       306 ff00::/8     On-link
7       266 ff00::/8     On-link
=====
Route permanenti:
Nessuna
```

Quali informazioni puoi ottenere dalla scheda Dettagli e dalla finestra di dialogo Proprietà per il PID selezionato?

Dallo screenshot relativo al PID 836 (corrispondente al processo svchost.exe collegato alla porta 3389/TermService in ascolto):

- **Scheda Dettagli (Gestione Attività):** Mostra il Nome del file (svchost.exe), il PID (836), lo Stato (In esecuzione), il Nome utente (SERVIZIO RETE), l'uso della CPU (00), l'occupazione di Memoria (4.900 K) e la Descrizione del processo (Processo host per servizi di Windows).
- **Finestra Proprietà:** Fornisce il Nome dell'eseguibile, il Tipo di file (Applicazione (.exe)), la Descrizione, il Percorso esatto sul disco (C:\Windows\System32), la Dimensione del file (38,9 KB), le Date di creazione, modifica e ultimo accesso (venerdì 10 luglio 2015) e gli Attributi del file (es. Sola lettura, Nascosto).



Cosa è successo ai file nel Cestino?

In PowerShell è stato eseguito il cmdlet **Clear-RecycleBin**. Dopo la richiesta di conferma dall'utente (risposta [S] Sì), tutto il contenuto del Cestino è stato svuotato ed eliminato definitivamente dal sistema.

```
PS C:\Windows\system32> clear-recyclebin

Conferma
Eseguire l'operazione?
Esecuzione dell'operazione "Clear-RecycleBin" sulla destinazione "Tutto il contenuto del Cestino".
[S] Sì [T] Sì a tutti [N] No [U] No a tutti [O] Sospendi [?] Guida (il valore predefinito è "s"): s
```

Domanda di riflessione: Comandi PowerShell per la Cybersecurity

I cmdlet di PowerShell sono fondamentali nell'analisi di sicurezza per condurre attività di triage, Incident Response e caccia alle minacce (Threat Hunting). Tra i comandi mostrati negli screenshot e quelli comunemente usati dagli analisti di sicurezza figurano:

- **Analisi di Rete e Connessioni:**
 - `Get-NetTCPConnection`: Elenca tutte le connessioni TCP attive, le porte locali/remote e lo stato della connessione (ascolto, stabilita, ecc.), sostituendo il classico `netstat`.
 - `Get-DnsClientCache`: Mostra la cache DNS locale per individuare eventuali domini malevoli contattati di recente dal sistema.
- **Analisi dei Processi e Servizi:**
 - `Get-Process`: Elenca tutti i processi in esecuzione con ID (PID), utilizzo di memoria, CPU e nome dell'eseguibile.

- Get-Service: Rileva lo stato di tutti i servizi di sistema (in esecuzione o arrestati) per individuare eventuali servizi sospetti installati da malware.
- **Monitoraggio della Sicurezza e Log di Eventi:**
 - Get-WinEvent / Get-EventLog: Consente di filtrare e analizzare i registri eventi di Windows (Security, System, Application) per cercare tentativi di accesso falliti, privilege escalation o anomalie.
 - Get-MpComputerStatus / Get-MpThreat: Permette di verificare lo stato di Windows Defender e l'elenco delle minacce rilevate direttamente da riga di comando.

```

Amministratore: Windows PowerShell
PS C:\Windows\system32> Get-DnsClientCache

Entry                RecordName                Record Type Status      Section TimeTo Live Data Length Data
-----
safebrowsing.googleapi... safebrowsing.googleapi... A          Success    Answer   154      4      74.125.197.95
ldap._tcp.defaultfir... ldap._tcp.defaultfir... A          NotExist   Answer   199      4      142.250.69.78
clientservices.googlelea... clientservices.googlelea... A          Success    Answer   199      4      142.250.69.78
ldap._tcp.pdc._msdcs... ldap._tcp.pdc._msdcs... A          NotExist   Answer   199      4      142.250.69.78
wpad                  wpad                      A          NotExist   Answer   199      4      142.250.69.78
ldap._tcp.dc._msdcs.e... ldap._tcp.dc._msdcs.e... A          NotExist   Answer   199      4      142.250.69.78

PS C:\Windows\system32> Get-Process

Handles  NPM(K)  PM(K)  WS(K) VM(M)  CPU(s)  Id ProcessName
-----
311      30      13232  3008  ...89  1.03    756 chrome
126      8      1932   448  ...62  0.05    884 chrome
303      21     15388  18700 ...64  4.52   3600 chrome
1348     57     73940  43088 ...66  8.81   4088 chrome
310      18     38100  4132  ...19  0.89   5168 chrome
217      18     23548  4012  ...10  0.33   5256 chrome
175      13      9064  1928  ...66  0.17   6296 chrome
168      13     8920   1876  ...58  0.09   6748 chrome
239      30     68760  20432 ...33  1.23   7828 chrome
54       6       684    3284  ...77  0.02   2660 conhost
104      8      10116  7016  ...15  0.05   2720 conhost
112      10     4624   12484 ...46  6.75   5052 conhost
303      15     1160   3164  ...02  0.38   360 csrss
302      17     1300   4484  ...15  9.22   448 csrss
362      32     40960  63732 ...23  9.91   900 dwm
1638     65     22892  10764 ...51  9.11   3608 explorer
0       0       0       4      0      1.84    0 Idle
900      29     4620   12124 ...02  1.84   564 lsass
318      29     3596   8748  ...35  0.05   1656 msasvc
354      23     4628   492    124  0.48   3636 OneDrive
126      9      1668   5444  ...67  0.02   2224 pg_ctl
328      12     3336   11332  91    0.05   2708 postgres
279      9      2508   3468  ...89  0.03   2852 postgres
276      9      2560   3720  ...89  0.02   2952 postgres
276      9      2556   3808  ...85  0.02   2964 postgres
276      9      2572   3668  ...85  0.02   2972 postgres
278      9      3800   4764  ...87  0.03   2984 postgres
278      9      2484   3772  ...85  0.02   2992 postgres
713      43     128596  132720 ...60  9.70   5200 powershell
414      27     9644   32752 ...73  1.03   6520 RuntimeBroker
748      63     25596  27960 ...58  6.77   4076 SearchIndexer
1077     67     50624  101392 33125 3.72   6512 SearchUI

```

```

Amministratore: Windows PowerShell
PS C:\Windows\system32> Get-NetTCPConnection

LocalAddress LocalPort RemoteAddress RemotePort State AppliedSetting
-----
::: 49451 ::: 0 Listen
::: 49416 ::: 0 Listen
::: 49415 ::: 0 Listen
::: 49414 ::: 0 Listen
::: 49412 ::: 0 Listen
::: 49411 ::: 0 Listen
::: 49410 ::: 0 Listen
::: 49409 ::: 0 Listen
::: 49408 ::: 0 Listen
::: 8443 ::: 0 Listen
::: 5432 ::: 0 Listen
::: 5357 ::: 0 Listen
::: 3389 ::: 0 Listen
::: 2107 ::: 0 Listen
::: 2105 ::: 0 Listen
::: 2103 ::: 0 Listen
::: 1801 ::: 0 Listen
::: 445 ::: 0 Listen
::: 135 ::: 0 Listen
::: 80 ::: 0 Listen
::: 19 ::: 0 Listen
::: 17 ::: 0 Listen
::: 13 ::: 0 Listen
::: 9 ::: 0 Listen
::: 7 ::: 0 Listen
0.0.0.0 49584 0.0.0.0 0 Bound
0.0.0.0 49583 0.0.0.0 0 Bound
0.0.0.0 49582 0.0.0.0 0 Bound
0.0.0.0 49581 0.0.0.0 0 Bound
0.0.0.0 49578 0.0.0.0 0 Bound
0.0.0.0 49475 0.0.0.0 0 Bound
0.0.0.0 49450 0.0.0.0 0 Bound
0.0.0.0 49448 0.0.0.0 0 Bound
0.0.0.0 49446 0.0.0.0 0 Bound
0.0.0.0 49444 0.0.0.0 0 Bound
0.0.0.0 49442 0.0.0.0 0 Bound
0.0.0.0 49440 0.0.0.0 0 Bound
0.0.0.0 49438 0.0.0.0 0 Bound
0.0.0.0 49436 0.0.0.0 0 Bound
0.0.0.0 49434 0.0.0.0 0 Bound
0.0.0.0 49432 0.0.0.0 0 Bound
0.0.0.0 49430 0.0.0.0 0 Bound
0.0.0.0 49428 0.0.0.0 0 Bound
0.0.0.0 49426 0.0.0.0 0 Bound
0.0.0.0 49424 0.0.0.0 0 Bound
0.0.0.0 49422 0.0.0.0 0 Bound

```


PS C:\windows\system32> Get-Service

Status	Name	DisplayName
Stopped	AJRouter	Servizio router AllJoyn
Stopped	ALC	Servizio Gateway di livello applica...
Running	AppHostSvc	Servizio Application Host Helper
Stopped	AppIDSvc	Identità applicazione
Stopped	AppInfo	Informazioni applicazioni
Stopped	AppMgmt	Gestione applicazione
Stopped	AppReadiness	Preparazione app
Stopped	AppXSvc	Servizio di distribuzione AppX (App...
Running	AudioEndpointBu...	Generatore endpoint audio Windows
Running	AudioSrv	Audio di Windows
Stopped	AxInstSV	ActiveX Installer (AxInstSV)
Stopped	BDESVC	Servizio di crittografia unità BitL...
Running	BFE	BFE (Base Filtering Engine)
Running	BITS	Servizio trasferimento intelligente...
Running	BrokerInfrastru...	Servizio infrastruttura attività in...
Running	Browser	Browser di computer
Stopped	BthHFSrv	Servizio viva voce Bluetooth
Stopped	bthserv	Servizio Supporto Tecnico Bluetooth
Stopped	CDPSvc	CDPSvc
Running	CertPropSvc	Propagazione certificati
Running	ClipSvc	Servizio licenze client (ClipSvc)
Stopped	COMSysApp	Applicazione di sistema COM+
Running	CoreMessagingRe...	CoreMessaging
Running	CryptSvc	Servizi di crittografia
Stopped	CscService	File non linea
Running	DcomLaunch	Utilità di avvio processi server DCOM
Stopped	DcpSvc	DataCollectionPublishingService
Stopped	defragsvc	Ottimizza unità
Stopped	DeviceAssociati...	Servizio associazione dispositivi
Stopped	DeviceInstall	Servizio installazione dispositivi
Stopped	DevQueryBroker	Gestore individuazione in backgroun...
Running	Dhcp	Client DHCP
Stopped	diagnosticshub....	Servizio Agente di raccolta standar...
Stopped	DiagTrack	Servizio Monitoraggio diagnostica
Stopped	DmEnrollmentSvc	Servizio di registrazione gestione ...
Stopped	dmwappushservice	dmwappushsvc
Running	Dnscache	Client DNS
Stopped	DoSvc	Ottimizzazione recapito
Stopped	dot3svc	Configurazione automatica reti cablate
Running	DPS	Servizio Criteri di diagnostica
Stopped	DsmSvc	Gestione configurazione dispositivi
Stopped	DsRoleSvc	Ruolo server DS
Stopped	DsSvc	Servizio di condivisione dati
Stopped	Eaphost	Extensible Authentication Protocol
Stopped	EFS	EFS (Encrypting File System)
Stopped	embeddedmode	embeddedmode

Esercizio 2 – Studio di IoC

Analisi della Minaccia via ANY.RUN

1. Origine d'attacco e il contesto di esecuzione

Ho analizzato la sessione all'interno dell'ambiente sandbox di ANY.RUN, eseguita su un sistema Windows 10 a 64 bit (durata totale dell'analisi: circa 314 secondi). Ho riscontrato che dall'istanza principale di Firefox (PID 6596) è stato scaricato ed eseguito il file malevolo Jvczfhe.exe (PID 7492), salvato nella directory C:\Users\admin\Downloads\.

2. Indicatori generali e consumo di risorse

Ho monitorato gli indicatori principali d'impatto sulla macchina virtuale, rilevando attività di rete, modifiche al file system, alterazioni del Registro di sistema e iniezione di processi. Ho inoltre osservato distinti picchi di utilizzo di CPU e RAM in corrispondenza dell'avvio dei payload.

3. Process Graph: l'albero dei processi e la catena di infezione

Ho esaminato il grafico dei processi per ricostruire l'ordine di esecuzione:

- Il browser firefox.exe (PID 6596) ha avviato il primo eseguibile Jvczfhe.exe (PID 7492).
- Successivamente è stato eseguito un secondo processo sospetto, Muadnrd.exe (PID 7824), anch'esso figlio del ramo firefox.exe.
- Entrambi i processi hanno invocato la Shell di Windows (cmd.exe PID 7520 e PID 7876), ciascuna delle quali ha a sua volta generato conhost.exe e timeout.exe, quest'ultimo usato per ritardare l'esecuzione dei comandi.
- In parallelo alla shell, sia Jvczfhe.exe sia Muadnrd.exe hanno avviato direttamente le minacce reali sul sistema (THREAT): rispettivamente InstallUtil.exe (PID 5152) e un'ulteriore istanza di Muadnrd.exe (PID 7248).
- L'esecuzione di entrambi i rami ha inoltre generato un crash applicativo, con conseguente avvio di WerFault.exe.



Immagine 1 – Process Graph: catena di esecuzione da firefox.exe a Jvczfhe.exe, Muadnrd.exe e ai processi THREAT (InstallUtil.exe, Muadnrd.exe).

4. Verifica metadati dei file e tecniche di mascheramento

Nelle schede di dettaglio di Jvczfhe.exe e Muadnrd.exe, ho notato che entrambi i file sono stati avviati sotto l'account admin con un livello di integrità medio (IL: MEDIUM):

- Firma digitale: ho riscontrato la voce Code signing: Untrusted, confermando che gli eseguibili non possedevano un certificato valido.
- Spoofing dei metadati: ho notato un tentativo di camuffamento, poiché entrambi i file riportavano falsamente nei metadati la descrizione "Microsoft Edge" e l'azienda produttrice "Microsoft Corporation" (Versione 126.0.2592.113).

5. Dettagli, Score e le TTPs (Tactics, Techniques, and Procedures) dei singoli processi

Approfondendo la valutazione dei due processi chiave:

Jvczfhe.exe (PID 7492): ha ottenuto uno score di minaccia pari a 51/100 (Suspicious). Ho rilevato che ha tentato di disabilitare il logging degli eventi di Windows (T1562.002 – Disable Windows Event Logging), ha letto le impostazioni di sicurezza di Internet Explorer e le informazioni proxy, ha avviato la shell di comando (T1059.003) e ha lanciato un'applicazione che è andata in crash.

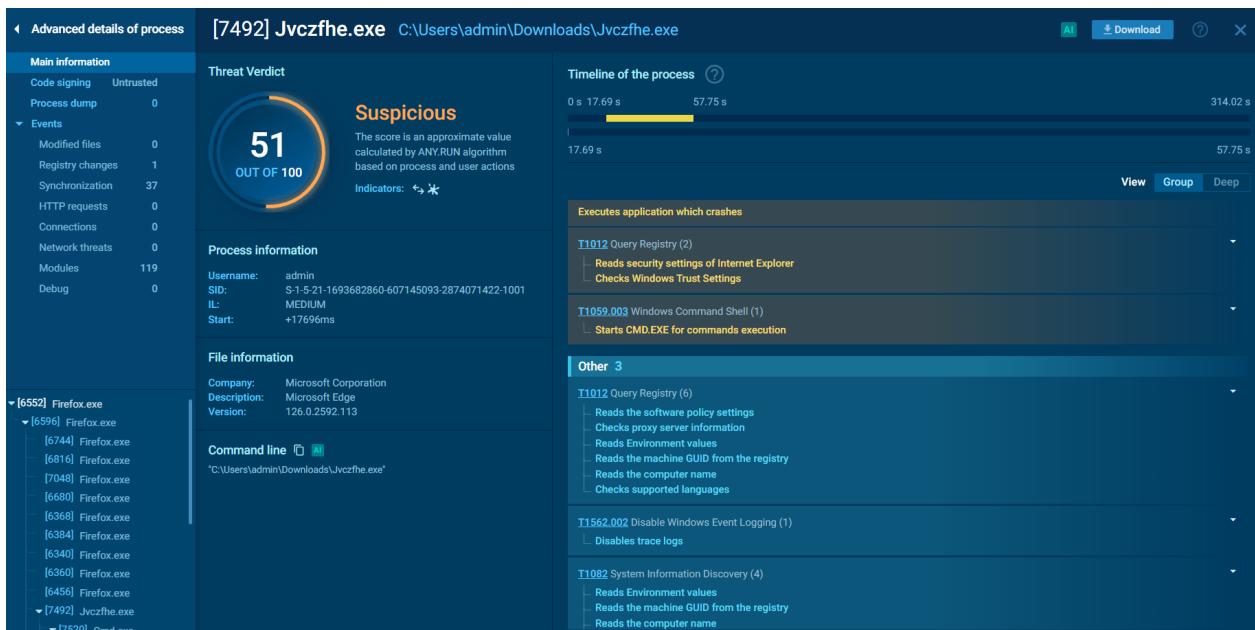


Immagine 2 – Dettaglio del processo Jvczfhe.exe (PID 7492): score, metadati e TTP rilevate.

Muadnrd.exe (PID 7824): ha ottenuto uno score di minaccia pari a 62/100 (Suspicious). Ho riscontrato le medesime tecniche TTP (lettura del registro, avvio della shell cmd.exe e disattivazione del tracciamento eventi), oltre al fatto che l'applicazione si è auto-rilanciata ("Application launched itself").

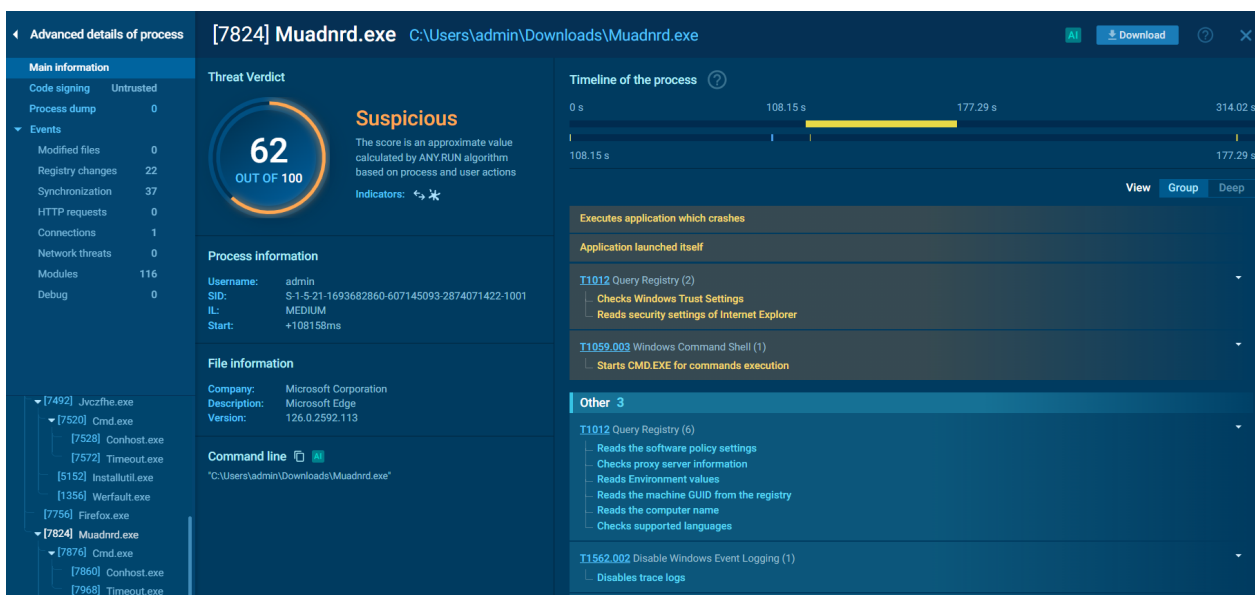


Immagine 3 – Dettaglio del processo Muadnrd.exe (PID 7824): score, metadati e TTP rilevate.

6. Verifica attività comportamentali (Behavior Activities)

Nel riepilogo generale delle azioni eseguite sul sistema possiamo notare:

Attività Sospette (Suspicious): ho confermato che Jvczfhe.exe e Muadnrd.exe hanno letto le

impostazioni di sicurezza di Internet Explorer, verificato le opzioni di Windows Trust ed eseguito un'applicazione che è andata in crash. Ho inoltre notato che sono stati i processi cmd.exe (PID 7520 e PID 7876), e non direttamente Jvczfhe.exe o Muadnrd.exe, a usare TIMEOUT.EXE per ritardare le azioni. Ho infine osservato che InstallUtil.exe (PID 5152) ha tentato connessioni su una porta di rete insolita ("Connects to unusual port") e che firefox.exe (PID 6596) ha rilasciato sul disco un eseguibile legittimo di Windows ("Process drops legitimate windows executable").

Attività Informative (Info): ho osservato una costante attività di reconnaissance da parte dei processi malevoli (Jvczfhe.exe, InstallUtil.exe, Muadnrd.exe), tra cui la lettura del nome del computer, dei valori d'ambiente, del GUID della macchina dal registro e la verifica delle impostazioni proxy, oltre al fatto che sia firefox.exe (PID 6596) sia firefox.exe (PID 6552) risultano essersi "auto-rilanciati" (Application launched itself).

Behavior activities

☒ Add for printing 

MALICIOUS

No malicious indicators.

SUSPICIOUS

- Process drops legitimate windows executable
 - firefox.exe (PID: 6596)
- Starts CMD.EXE for commands execution
 - Jvczfhe.exe (PID: 7492)
 - Muadnrd.exe (PID: 7824)
- Uses TIMEOUT.EXE to delay execution
 - cmd.exe (PID: 7520)
 - cmd.exe (PID: 7876)
- Reads security settings of Internet Explorer
 - Jvczfhe.exe (PID: 7492)
 - Muadnrd.exe (PID: 7824)
- Executes application which crashes
 - Jvczfhe.exe (PID: 7492)
 - Muadnrd.exe (PID: 7824)
- Checks Windows Trust Settings
 - Jvczfhe.exe (PID: 7492)
 - Muadnrd.exe (PID: 7824)
- Connects to unusual port
 - InstallUtil.exe (PID: 5152)
- Application launched itself
 - Muadnrd.exe (PID: 7824)

INFO

- Application launched itself
 - firefox.exe (PID: 6596)
 - firefox.exe (PID: 6552)
- Executable content was dropped or overwritten
 - firefox.exe (PID: 6596)
- Reads Microsoft Office registry keys
 - firefox.exe (PID: 6596)
- Reads the computer name
 - Jvczfhe.exe (PID: 7492)
 - InstallUtil.exe (PID: 5152)
 - Muadnrd.exe (PID: 7824)
 - Muadnrd.exe (PID: 7248)
- Checks supported languages
 - Jvczfhe.exe (PID: 7492)
 - InstallUtil.exe (PID: 5152)
 - Muadnrd.exe (PID: 7824)
 - Muadnrd.exe (PID: 7248)
- Reads Environment values
 - Jvczfhe.exe (PID: 7492)
 - InstallUtil.exe (PID: 5152)
 - Muadnrd.exe (PID: 7824)
- Checks proxy server information
 - Jvczfhe.exe (PID: 7492)
 - WerFault.exe (PID: 1356)
 - Muadnrd.exe (PID: 7824)

Immagine 4 – Behavior activities: sintesi delle attività Malicious, Suspicious e Info rilevate durante l'analisi.

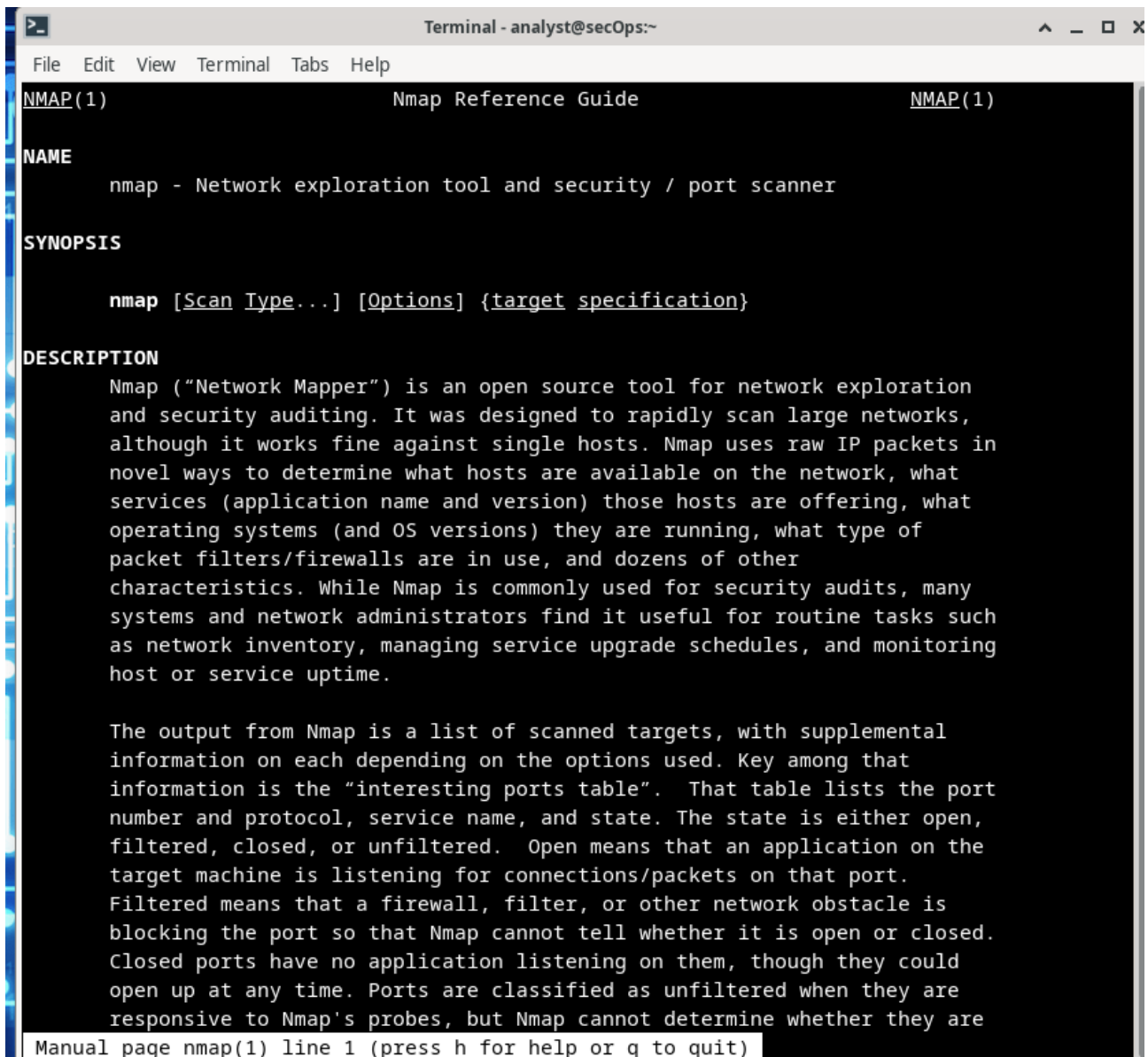
7. Instabilità del sistema

Infine, ho osservato che l'esecuzione di questi payload aggressivi ha causato molteplici crash di sistema. Questo ha forzato l'intervento del gestore di segnalazione errori di Windows (**WerFault.exe** PID 1356), il quale è stato monitorato mentre effettuava controlli sulle impostazioni del server proxy per tentare di inviare i report di errore a Microsoft, confermando l'instabilità generata dall'attacco sul sistema ospite.

Checks proxy server information

- Jvczfhe.exe (PID: 7492)
- WerFault.exe (PID: 1356)
- Muadnrd.exe (PID: 7824)

Esercizio Bonus 1 – Esplorazione Nmap

A screenshot of a terminal window titled "Terminal - analyst@secOps:~". The terminal displays the Nmap Reference Guide. At the top, there is a menu bar with "File", "Edit", "View", "Terminal", "Tabs", and "Help". Below the menu bar, the title "NMAP(1)" is on the left and "Nmap Reference Guide" is in the center, with another "NMAP(1)" on the right. The content is organized into sections: "NAME" with the description "nmap - Network exploration tool and security / port scanner"; "SYNOPSIS" with the command "nmap [Scan Type...] [Options] {target specification}"; and "DESCRIPTION" which contains two paragraphs. The first paragraph describes Nmap as an open source tool for network exploration and security auditing. The second paragraph describes the output of Nmap, specifically the "interesting ports table". At the bottom of the terminal, a status bar reads "Manual page nmap(1) line 1 (press h for help or q to quit)".

```
Terminal - analyst@secOps:~
File Edit View Terminal Tabs Help
NMAP(1)                                Nmap Reference Guide                                NMAP(1)

NAME
    nmap - Network exploration tool and security / port scanner

SYNOPSIS
    nmap [Scan Type...] [Options] {target specification}

DESCRIPTION
    Nmap ("Network Mapper") is an open source tool for network exploration
    and security auditing. It was designed to rapidly scan large networks,
    although it works fine against single hosts. Nmap uses raw IP packets in
    novel ways to determine what hosts are available on the network, what
    services (application name and version) those hosts are offering, what
    operating systems (and OS versions) they are running, what type of
    packet filters/firewalls are in use, and dozens of other
    characteristics. While Nmap is commonly used for security audits, many
    systems and network administrators find it useful for routine tasks such
    as network inventory, managing service upgrade schedules, and monitoring
    host or service uptime.

    The output from Nmap is a list of scanned targets, with supplemental
    information on each depending on the options used. Key among that
    information is the "interesting ports table". That table lists the port
    number and protocol, service name, and state. The state is either open,
    filtered, closed, or unfiltered. Open means that an application on the
    target machine is listening for connections/packets on that port.
    Filtered means that a firewall, filter, or other network obstacle is
    blocking the port so that Nmap cannot tell whether it is open or closed.
    Closed ports have no application listening on them, though they could
    open up at any time. Ports are classified as unfiltered when they are
    responsive to Nmap's probes, but Nmap cannot determine whether they are

Manual page nmap(1) line 1 (press h for help or q to quit)
```

Cos'è Nmap?

Nmap (*Network Mapper*) è uno strumento open source per l'esplorazione di rete e l'audit di sicurezza, progettato per scansionare rapidamente reti di grandi dimensioni ma adatto anche a singoli host.

Per cosa viene usato Nmap?

Viene impiegato per la scoperta di host su una rete, l'identificazione delle porte aperte, la rilevazione dei servizi attivi e delle relative versioni, l'individuazione del sistema operativo e l'analisi di vulnerabilità o configurazioni errate.

```
Terminal - analyst@secOps:~
File Edit View Terminal Tabs Help

Example 1. A representative Nmap scan

# nmap -A -T4 scanme.nmap.org

Nmap scan report for scanme.nmap.org (74.207.244.221)
Host is up (0.029s latency).
rDNS record for 74.207.244.221: li86-221.members.linode.com
Not shown: 995 closed ports
PORT      STATE      SERVICE      VERSION
22/tcp    open      ssh          OpenSSH 5.3p1 Debian 3ubuntu7 (protocol 2.0)
| ssh-hostkey: 1024 8d:60:f1:7c:ca:b7:3d:0a:d6:67:54:9d:69:d9:b9:dd (DSA)
|_2048 79:f8:09:ac:d4:e2:32:42:10:49:d3:bd:20:82:85:ec (RSA)
80/tcp    open      http         Apache httpd 2.2.14 ((Ubuntu))
|_http-title: Go ahead and ScanMe!
646/tcp   filtered  ldp
1720/tcp  filtered  H.323/Q.931
9929/tcp  open      nping-echo   Nping echo
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6.39
OS details: Linux 2.6.39
Network Distance: 11 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:kernel

TRACEROUTE (using port 53/tcp)
HOP RTT      ADDRESS
[Cut first 10 hops for brevity]
11  17.65 ms li86-221.members.linode.com (74.207.244.221)

Nmap done: 1 IP address (1 host up) scanned in 14.40 seconds

The newest version of Nmap can be obtained from https://nmap.org. The newest
version of this man page is available at https://nmap.org/book/man.html. It is
Manual page nmap(1) line 46/2815 2% (press h for help or q to quit)
```

Cosa fa l'opzione -A?

L'opzione -A abilita il rilevamento avanzato e aggressivo. Attiva contemporaneamente:

- Il rilevamento del sistema operativo (*OS detection*).
- La scansione delle versioni dei servizi (*version detection*).
- La scansione tramite script Nmap (*Nmap Scripting Engine - NSE*).
- Il tracciamento del percorso di rete (*traceroute*).

Cosa fa l'opzione -T4?

Imposta la velocità di scansione (tempistica). -T4 imposta il profilo *Aggressive*, che velocizza la scansione riducendo i tempi di attesa per i timeout, ideale per reti stabili e veloci.

```
Terminal - analyst@secOps:~
File Edit View Terminal Tabs Help

[analyst@secOps ~]$ nmap -A -T4 localhost
Starting Nmap 7.97 ( https://nmap.org ) at 2026-09-04 08:42 -0400
Failed to resolve "-A".
Failed to resolve "-T4".
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000027s latency).
Other addresses for localhost (not scanned): ::1
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh

Nmap done: 1 IP address (1 host up) scanned in 4.04 seconds
[analyst@secOps ~]$ nmap -sV localhost
Starting Nmap 7.97 ( https://nmap.org ) at 2026-09-04 08:42 -0400
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000034s latency).
Other addresses for localhost (not scanned): ::1
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.0.8 or later
22/tcp    open  ssh      OpenSSH 10.0 (protocol 2.0)
Service Info: Host: Welcome

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.35 seconds
[analyst@secOps ~]$ ip address
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:2f:87:a7 brd ff:ff:ff:ff:ff:ff
    altname enx0800272f87a7
    inet 10.0.2.15/24 metric 1024 brd 10.0.2.255 scope global dynamic enp0s3
        valid_lft 85536sec preferred_lft 85536sec
    inet6 fd17:625c:f037:2:a00:27ff:fe2f:87a7/64 scope global dynamic mngtmpaddr noprefixroute
```

Quali porte e servizi sono aperti?

Per ognuna delle porte aperte, registra il software che fornisce i servizi.

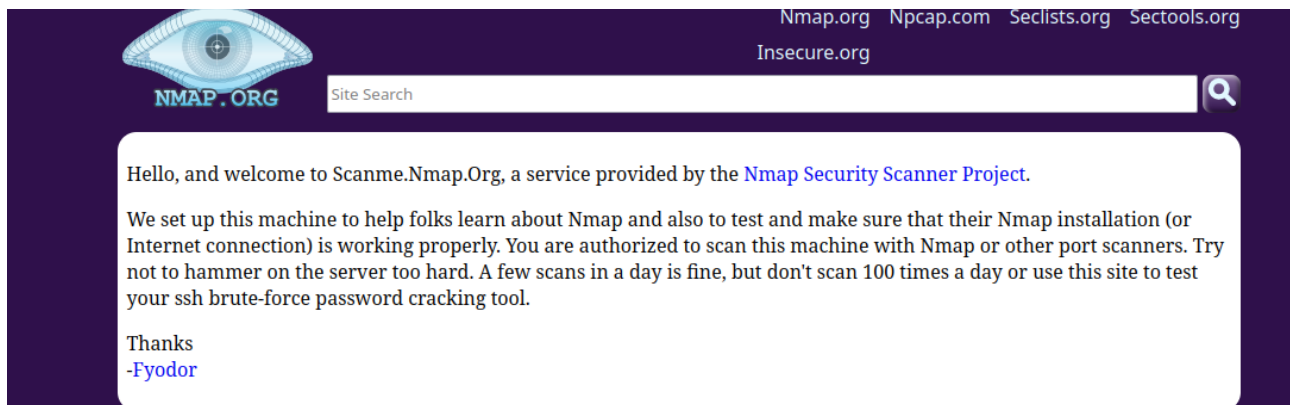
- **Porta 21/TCP (FTP):** Servizio FTP - *vsftpd 2.0.8*
- **Porta 22/TCP (SSH):** Servizio SSH - *OpenSSH 10.0 (protocol 2.0)*

A quale rete appartiene la tua VM?

La VM appartiene alla rete NAT di VirtualBox configurata nell'ambiente CyberOps, con indirizzo IP **10.0.2.0/24** (IP host 10.0.2.15).

Scopo del sito scanme.nmap.org

Il messaggio pubblicato indica che `scanme.nmap.org` è un server messo a disposizione dal team di Nmap per consentire agli utenti di testare il funzionamento dello strumento senza effettuare scansioni non autorizzate su terzi.



Quali porte e servizi sono aperti?

- **22/TCP (SSH):** OpenSSH
- **80/TCP (HTTP):** Apache httpd

Quali porte e servizi sono filtrati?

- La porta **135/tcp** (msrpc)
- La porta **139/tcp** (netbios-ssn)
- La porta **445/tcp** (microsoft-ds)

Qual è l'indirizzo IP del server?

L'indirizzo IP di `scanme.nmap.org` è **45.33.32.156**.

Qual è il sistema operativo?

Il sistema operativo rilevato è **Linux**

Domanda di Riflessione

- **Come può Nmap aiutare con la sicurezza della rete?**

Nmap aiuta gli amministratori e gli analisti di sicurezza a mappare la superficie d'attacco dell'azienda. Permette di scoprire dispositivi non autorizzati o dimenticati (rogue devices), identificare porte lasciate aperte per errore, verificare che i firewall funzionino correttamente e rilevare software o servizi non aggiornati affetti da vulnerabilità note.

- **Come può Nmap essere usato da un attore malevolo come strumento nefasto?**

Un attaccante usa Nmap nella fase preliminare di ricognizione (*Reconnaissance*) per

mappare l'infrastruttura bersaglio. Identificando le porte aperte, i sistemi operativi e le esatte versioni dei software in esecuzione, l'attaccante può cercare exploit specifici per penetrare nella rete.

Esercizio Bonus 2 – Attacco a un Database MySQL

Qual è la versione?

La versione del database MySQL estratta dall'attaccante tramite l'iniezione (1' or 1=1 union select null, version()#) è **5.7.12-0ubuntu 1.1**.

Quale utente ha l'hash della password di 8d3533d75ae2c3966d7e0d4fcc69216b?

- L'utente associato a questo hash MD5 nel database è **1337**.

Qual è la password in chiaro?

- Inserendo l'hash 8d3533d75ae2c3966d7e0d4fcc69216b su CrackStation, la password decifrata in chiaro risulta essere **charley**.

Domande di Riflessione

1. Qual è il rischio che le piattaforme utilizzino il linguaggio SQL?

Il rischio principale risiede nel fatto che se l'applicazione web non convalida o non gestisce correttamente gli input forniti dagli utenti (es. tramite form di login o barre di ricerca), un attaccante può inserire istruzioni SQL arbitrarie. Questo permette di bypassare i sistemi di autenticazione, leggere dati sensibili (come credenziali e hash), modificare o eliminare tabelle del database e, nei casi più gravi, eseguire comandi a livello di sistema operativo.

2. Quali sono 2 metodi o passaggi che possono essere adottati per prevenire gli attacchi di SQL injection?

- **Filtrare e convalidare l'input dell'utente:** Verificare e sanitizzare tutti i dati in ingresso lato server per garantire che contengano solo caratteri o formati previsti, bloccando comandi o caratteri speciali pericolosi.
- **Utilizzare parametri con query o stored procedure (Query Parametrizzate):** Separare nettamente il codice SQL dai dati forniti dall'utente, impedendo che i dati inseriti vengano interpretati come istruzioni eseguibili.
- **Implementare un Web Application Firewall (WAF):** Monitorare e filtrare il traffico HTTP verso l'applicazione web per rilevare e bloccare i pattern di attacco SQLi comuni prima che raggiungano il database.
- **Applicare il principio del minimo privilegio e disabilitare funzionalità non necessarie:** Limitare le autorizzazioni dell'account del database usato dall'applicazione e disattivare estensioni o funzioni non indispensabili per ridurre la superficie di attacco.